

DAST OWASP ZAP Scan Results

Baseline scan against <https://roomclarity.com> - final successful workflow run 26339140824

Scan Summary

Field	Value
Tool	OWASP ZAP Baseline
Target	https://roomclarity.com
Workflow run	26339140824
Conclusion	Success
High alerts	0
Medium alerts	2
Low alerts	5
Informational alerts	4

Report Detail

ZAP by [Checkmarx](<https://checkmarx.com/>).

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	5
Informational	4

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	https://roomclarity.com	Percentage of responses with status code 2xx	86 %
Info	Informational	https://roomclarity.com	Percentage of responses with status code 4xx	13 %
Info	Informational	https://roomclarity.com	Percentage of endpoints with content type image/png	7 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://roomclarity.com	Percentage of endpoints with content type text/css	7 %
Info	Informational	https://roomclarity.com	Percentage of endpoints with content type text/html	53 %
Info	Informational	https://roomclarity.com	Percentage of endpoints with content type text/javascript	15 %
Info	Informational	https://roomclarity.com	Percentage of endpoints with content type text/plain	15 %
Info	Informational	https://roomclarity.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://roomclarity.com	Count of total endpoints	13
Info	Informational	https://roomclarity.com	Percentage of slow responses	73 %

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	Systemic
Sub Resource Integrity Attribute Missing	Medium	3
Cross-Domain JavaScript Source File Inclusion	Low	3
Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	4
Cross-Origin-Opener-Policy Header Missing or Invalid	Low	4
Cross-Origin-Resource-Policy Header Missing or Invalid	Low	4
Permissions Policy Header Not Set	Low	Systemic
Modern Web Application	Informational	1
Non-Storable Content	Informational	Systemic
Re-examine Cache-control Directives	Informational	Systemic
Storable and Cacheable Content	Informational	2

Alert Detail

[CSP: Failure to Define Directive with No Fallback](<https://www.zaproxy.org/docs/alerts/10055/>)

Medium (High)

Description

The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.

* URL: <https://roomclarity.com>

* Node Name: <https://roomclarity.com>

* Method: GET

* Parameter: content-security-policy

* Attack: ``

* Evidence: default-src 'self'; script-src 'self' <https://appssdk.zoom.us>; style-src 'self'; img-src 'self' data:; connect-src 'self'; frame-ancestors 'self' https://*.zoom.us https://*.zoom.com

* Other Info: The directive(s): form-action is/are among the directives that do not fallback to default-src.

* URL: <https://roomclarity.com/>

* Node Name: <https://roomclarity.com/>

* Method: GET

* Parameter: content-security-policy

* Attack: ``

* Evidence: default-src 'self'; script-src 'self' <https://appssdk.zoom.us>; style-src 'self'; img-src 'self' data:; connect-src 'self'; frame-ancestors 'self' https://*.zoom.us https://*.zoom.com

* Other Info: The directive(s): form-action is/are among the directives that do not fallback to default-src.

* URL: <https://roomclarity.com/app>

* Node Name: <https://roomclarity.com/app>

* Method: GET

* Parameter: content-security-policy

* Attack: ``

* Evidence: default-src 'self'; script-src 'self' <https://appssdk.zoom.us>; style-src 'self'; img-src 'self' data:; connect-src 'self'; frame-ancestors 'self' https://*.zoom.us https://*.zoom.com

* Other Info: The directive(s): form-action is/are among the directives that do not fallback to default-src.

* URL: <https://roomclarity.com/privacy.html>

* Node Name: <https://roomclarity.com/privacy.html>

* Method: GET

* Parameter: content-security-policy

* Attack: ``

* Evidence: default-src 'self'; script-src 'self' https://appssdk.zoom.us; style-src 'self'; img-src 'self' data:; connect-src 'self'; frame-ancestors 'self' https://*.zoom.us https://*.zoom.com

* Other Info: The directive(s): form-action is/are among the directives that do not fallback to default-src.

* URL: <https://roomclarity.com/support.html>

* Node Name: <https://roomclarity.com/support.html>

* Method: GET

* Parameter: content-security-policy

* Attack: ``

* Evidence: default-src 'self'; script-src 'self' https://appssdk.zoom.us; style-src 'self'; img-src 'self' data:; connect-src 'self'; frame-ancestors 'self' https://*.zoom.us https://*.zoom.com

* Other Info: The directive(s): form-action is/are among the directives that do not fallback to default-src.

Instances: Systemic

Solution

Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.

Reference

* <https://www.w3.org/TR/CSP/>

* <https://caniuse.com/#search=content+security+policy>

* <https://content-security-policy.com/>

* <https://github.com/HtmlUnit/htmlunit-csp>

* <https://web.dev/articles/csp#resource-options>

CWE Id: [693](<https://cwe.mitre.org/data/definitions/693.html>)

WASC Id: 15

Source ID: 3

[Sub Resource Integrity Attribute Missing](<https://www.zaproxy.org/docs/alerts/90003/>)

Medium (High)

Description

The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.

* URL: <https://roomclarity.com>

* Node Name: <https://roomclarity.com>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: `<script src="https://appssdk.zoom.us/sdk.js"></script>`

* Other Info: ``

* URL: <https://roomclarity.com/>

* Node Name: <https://roomclarity.com/>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: `<script src="https://appssdk.zoom.us/sdk.js"></script>`

* Other Info: ``

* URL: <https://roomclarity.com/app>

* Node Name: <https://roomclarity.com/app>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: `<script src="https://appssdk.zoom.us/sdk.js"></script>`

* Other Info: ``

Instances: 3

Solution

Provide a valid integrity attribute to the tag.

Reference

* [https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity](https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity)

CWE Id: [345](<https://cwe.mitre.org/data/definitions/345.html>)

WASC Id: 15

Source ID: 3

[Cross-Domain JavaScript Source File Inclusion](<https://www.zaproxy.org/docs/alerts/10017/>)

Low (Medium)

Description

The page includes one or more script files from a third-party domain.

* URL: <https://roomclarity.com>

* Node Name: <https://roomclarity.com>

* Method: GET

* Parameter: <https://appssdk.zoom.us/sdk.js>

* Attack: ``

* Evidence: `<script src="https://appssdk.zoom.us/sdk.js"></script>`

* Other Info: ``

* URL: <https://roomclarity.com/>

* Node Name: <https://roomclarity.com/>

* Method: GET

* Parameter: <https://appssdk.zoom.us/sdk.js>

* Attack: ``

* Evidence: `<script src="https://appssdk.zoom.us/sdk.js"></script>`

* Other Info: ``

* URL: <https://roomclarity.com/app>

* Node Name: <https://roomclarity.com/app>

* Method: GET

* Parameter: <https://appssdk.zoom.us/sdk.js>

* Attack: ``

* Evidence: `<script src="https://appssdk.zoom.us/sdk.js"></script>`

* Other Info: ``

Instances: 3

Solution

Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.

Reference

CWE Id: [829](<https://cwe.mitre.org/data/definitions/829.html>)

WASC Id: 15

Source ID: 3

[Cross-Origin-Embedder-Policy Header Missing or Invalid](<https://www.zaproxy.org/docs/alerts/90004/>)

Low (Medium)

Description

Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).

* URL: <https://roomclarity.com>

* Node Name: <https://roomclarity.com>

* Method: GET

* Parameter: Cross-Origin-Embedder-Policy

* Attack: ``

* Evidence: ``

* Other Info: ``

* URL: <https://roomclarity.com/>

* Node Name: <https://roomclarity.com/>

* Method: GET

* Parameter: Cross-Origin-Embedder-Policy

* Attack: ``

* Evidence: ``

* Other Info: ``

* URL: <https://roomclarity.com/privacy.html>

* Node Name: <https://roomclarity.com/privacy.html>

* Method: GET

* Parameter: Cross-Origin-Embedder-Policy

* Attack: ``

* Evidence: ``

* Other Info: ``

* URL: <https://roomclarity.com/support.html>

* Node Name: <https://roomclarity.com/support.html>

* Method: GET

* Parameter: Cross-Origin-Embedder-Policy

* Attack: ``
* Evidence: ``
* Other Info: ``

Instances: 4

Solution

Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents.

If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).

Reference

* <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy>

CWE Id: [693](<https://cwe.mitre.org/data/definitions/693.html>)

WASC Id: 14

Source ID: 3

[Cross-Origin-Opener-Policy Header Missing or Invalid](<https://www.zaproxy.org/docs/alerts/90004/>)

Low (Medium)

Description

Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.

* URL: <https://roomclarity.com>
* Node Name: <https://roomclarity.com>
* Method: GET
* Parameter: Cross-Origin-Opener-Policy
* Attack: ``
* Evidence: ``
* Other Info: ``
* URL: <https://roomclarity.com/>
* Node Name: <https://roomclarity.com/>
* Method: GET
* Parameter: Cross-Origin-Opener-Policy

* Attack: ``
* Evidence: ``
* Other Info: ``
* URL: <https://roomclarity.com/privacy.html>
* Node Name: <https://roomclarity.com/privacy.html>
* Method: GET
* Parameter: Cross-Origin-Opener-Policy
* Attack: ``
* Evidence: ``
* Other Info: ``
* URL: <https://roomclarity.com/support.html>
* Node Name: <https://roomclarity.com/support.html>
* Method: GET
* Parameter: Cross-Origin-Opener-Policy
* Attack: ``
* Evidence: ``
* Other Info: ``
Instances: 4

Solution

Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents.

'same-origin-allow-popups' is considered as less secured and should be avoided.

If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

Reference

* [
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy>]
(<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy>)

CWE Id: [693](<https://cwe.mitre.org/data/definitions/693.html>)

WASC Id: 14

Source ID: 3

[Cross-Origin-Resource-Policy Header Missing or Invalid](<https://www.zaproxy.org/docs/alerts/90004/>)

Low (Medium)

Description

Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.

- * URL: <https://roomclarity.com>
- * Node Name: <https://roomclarity.com>
- * Method: GET
- * Parameter: Cross-Origin-Resource-Policy
- * Attack: ``
- * Evidence: ``
- * Other Info: ``
- * URL: <https://roomclarity.com/>
- * Node Name: <https://roomclarity.com/>
- * Method: GET
- * Parameter: Cross-Origin-Resource-Policy
- * Attack: ``
- * Evidence: ``
- * Other Info: ``
- * URL: <https://roomclarity.com/privacy.html>
- * Node Name: <https://roomclarity.com/privacy.html>
- * Method: GET
- * Parameter: Cross-Origin-Resource-Policy
- * Attack: ``
- * Evidence: ``
- * Other Info: ``
- * URL: <https://roomclarity.com/support.html>
- * Node Name: <https://roomclarity.com/support.html>
- * Method: GET
- * Parameter: Cross-Origin-Resource-Policy
- * Attack: ``
- * Evidence: ``
- * Other Info: ``

Instances: 4

Solution

Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages.

'same-site' is considered as less secured and should be avoided.

If resources must be shared, set the header to 'cross-origin'.

If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header
(https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).

Reference

* <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy>

CWE Id: [693](<https://cwe.mitre.org/data/definitions/693.html>)

WASC Id: 14

Source ID: 3

[Permissions Policy Header Not Set](<https://www.zaproxy.org/docs/alerts/10063/>)

Low (Medium)

Description

Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.

* URL: <https://roomclarity.com>

* Node Name: <https://roomclarity.com>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: ``

* Other Info: ``

* URL: <https://roomclarity.com/>

* Node Name: <https://roomclarity.com/>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: ``

* Other Info: ``

* URL: <https://roomclarity.com/documentation.html>

* Node Name: <https://roomclarity.com/documentation.html>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: ``

* Other Info: ``

* URL: <https://roomclarity.com/privacy.html>

* Node Name: <https://roomclarity.com/privacy.html>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: ``

* Other Info: ``

* URL: <https://roomclarity.com/support.html>

* Node Name: <https://roomclarity.com/support.html>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: ``

* Other Info: ``

Instances: Systemic

Solution

Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.

Reference

* <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy>

* <https://developer.chrome.com/blog/feature-policy/>

* <https://scotthelme.co.uk/a-new-security-header-feature-policy/>

* <https://w3c.github.io/webappsec-feature-policy/>

* <https://www.smashingmagazine.com/2018/12/feature-policy/>

CWE Id: [693](<https://cwe.mitre.org/data/definitions/693.html>)

WASC Id: 15

Source ID: 3

[Modern Web Application](<https://www.zaproxy.org/docs/alerts/10109/>)

Informational (Medium)

Description

The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.

* URL: <https://roomclarity.com/app>

* Node Name: <https://roomclarity.com/app>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: `<script src="https://appssdk.zoom.us/sdk.js"></script>`

* Other Info: No links have been found while there are scripts, which is an indication that this is a modern web application.

Instances: 1

Solution

This is an informational alert and so no changes are required.

Reference

Source ID: 3

[Non-Storable Content](<https://www.zaproxy.org/docs/alerts/10049/>)

Informational (Medium)

Description

The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.

* URL: <https://roomclarity.com>

* Node Name: <https://roomclarity.com>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: no-store

* Other Info: ``

* URL: <https://roomclarity.com/>
* Node Name: <https://roomclarity.com/>
* Method: GET
* Parameter: ``
* Attack: ``
* Evidence: no-store
* Other Info: ``

* URL: <https://roomclarity.com/documentation.html>
* Node Name: <https://roomclarity.com/documentation.html>
* Method: GET
* Parameter: ``
* Attack: ``
* Evidence: no-store
* Other Info: ``

* URL: <https://roomclarity.com/privacy.html>
* Node Name: <https://roomclarity.com/privacy.html>
* Method: GET
* Parameter: ``
* Attack: ``
* Evidence: no-store
* Other Info: ``

* URL: <https://roomclarity.com/support.html>
* Node Name: <https://roomclarity.com/support.html>
* Method: GET
* Parameter: ``
* Attack: ``
* Evidence: no-store
* Other Info: ``

Instances: Systemic

Solution

The content may be marked as storable by ensuring that the following conditions are satisfied:

The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable)

The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood)

The "no-store" cache directive must not appear in the request or response header fields

For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response

For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives)

In addition to the conditions above, at least one of the following conditions must also be satisfied by the response:

It must contain an "Expires" header field

It must contain a "max-age" response directive

For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive

It must contain a "Cache Control Extension" that allows it to be cached

It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).

Reference

* <https://datatracker.ietf.org/doc/html/rfc7234>

* <https://datatracker.ietf.org/doc/html/rfc7231>

* <https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html>

CWE Id: [524](<https://cwe.mitre.org/data/definitions/524.html>)

WASC Id: 13

Source ID: 3

[Re-examine Cache-control Directives](<https://www.zaproxy.org/docs/alerts/10015/>)

Informational (Low)

Description

The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.

* URL: <https://roomclarity.com>

* Node Name: <https://roomclarity.com>

* Method: GET

* Parameter: cache-control

* Attack: ``

* Evidence: no-store

* Other Info: ``

* URL: <https://roomclarity.com/>
* Node Name: <https://roomclarity.com/>
* Method: GET
* Parameter: cache-control
* Attack: ``
* Evidence: no-store
* Other Info: ``
* URL: <https://roomclarity.com/privacy.html>
* Node Name: <https://roomclarity.com/privacy.html>
* Method: GET
* Parameter: cache-control
* Attack: ``
* Evidence: no-store
* Other Info: ``
* URL: <https://roomclarity.com/support.html>
* Node Name: <https://roomclarity.com/support.html>
* Method: GET
* Parameter: cache-control
* Attack: ``
* Evidence: no-store
* Other Info: ``

Instances: Systemic

Solution

For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".

Reference

* [https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching](https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching)
* <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control>
* <https://grayduck.mn/2021/09/13/cache-control-recommendations/>

CWE Id: [525](<https://cwe.mitre.org/data/definitions/525.html>)

WASC Id: 13

Source ID: 3

**[Storable and Cacheable Content
(<https://www.zaproxy.org/docs/alerts/10049/>)**

Informational (Medium)

Description

The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

* URL: <https://roomclarity.com/meeting-decision-maker-icon.png>

* Node Name: <https://roomclarity.com/meeting-decision-maker-icon.png>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: max-age=300

* Other Info: ``

* URL: <https://roomclarity.com/robots.txt>

* Node Name: <https://roomclarity.com/robots.txt>

* Method: GET

* Parameter: ``

* Attack: ``

* Evidence: ``

* Other Info: In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.

Instances: 2

Solution

Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

Reference

* <https://datatracker.ietf.org/doc/html/rfc7234>

* <https://datatracker.ietf.org/doc/html/rfc7231>

* [<https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html>
](<https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html>)

CWE Id: [524](<https://cwe.mitre.org/data/definitions/524.html>)

WASC Id: 13

Source ID: 3